

TEMPLATE DE REPORTE EJECUTIVO

Plantilla Professional para Presentación de Resultados Encuesta

Versión: 1.0

Fecha: Enero 2026

Formato: Markdown (convertir a PowerPoint/PDF según necesidad)

Público: Junta Directiva, CEO, CFO, Auditores Externos

PORTADA RECOMENDADA

EVALUACIÓN DE MADUREZ CIBERSEGURIDAD 2026 - REPORTE EJECUTIVO

Organización: [NOMBRE]

Periodo Evaluado: Enero 2026

Clasificación: Información Confidencial - Gobierno Corporativo

Facilitador/Consultor: [NOMBRE]

Revisado por: [CISO/Responsable]

Aprobado por: [CEO/Director]

Fecha Publicación: [DD/MM/YYYY]

Próxima Evaluación: [DD/MM/YYYY + 12 meses]

SECCIÓN 1: RESUMEN EJECUTIVO (1 PÁGINA)

Mensaje Clave Principal

[Adaptar a situación específica]

SITUACIÓN ACTUAL:

La evaluación de madurez ciberseguridad 2026 revela una postura de seguridad de NIVEL [CRÍTICA/DÉBIL/ACEPTABLE/BUENA/EXCELENTE], con Índice de Gobernanza de Madurez (IGM) de ____ / 5.0.

IMPLICACIÓN PARA NEGOCIO:

La organización presenta [riesgos significativos sin mitigar / controles básicos inconsistentes / posición defensiva establecida], que expone a [operaciones / datos / reputación / cumplimiento] a riesgos cuantificables de €____ anuales.

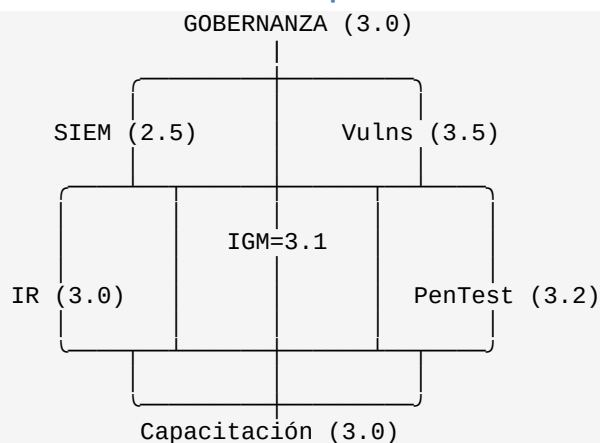
OPORTUNIDAD ESTRATÉGICA:

Inversión de €____ millones en mejora de ciberseguridad durante 18-24 meses genera retorno de seguridad (ROSI) de __%, evitando riesgos potenciales por €____ y fortaleciendo resiliencia competitiva.

ACCIÓN RECOMENDADA:

Aprobar hoja de ruta de mejora con horizonte 18-24 meses, asignando [X presupuesto] y [Y recursos], bajo liderazgo de CISO con gobernanza de junta trimestral.

Gráfico Radar - Puntuación por Dominio



IGM Promedio: 3.1 / 5.0 (Aceptable, bajo target 3.8)

Posición: 45° percentil vs benchmark industria

Tabla Resumen

Dominio	Actual	Target	Gap	Prioridad	Estado
Gobernanza	3.0	3.8	-0.8	Media	⚠
Vulnerabilidades	3.5	3.9	-0.4	Baja	✓ Aceptable
Pen Testing	3.2	3.5	-0.3	Baja	✓ Aceptable
SIEM	2.5	3.8	-1.3	CRÍTICA	🔴 Brecha
Incidentes	3.0	3.6	-0.6	Media	⚠
Capacitación	3.0	3.5	-0.5	Media	⚠
IGM GLOBAL	3.1	3.8	-0.7	Media	🟡 Retraso

SECCIÓN 2: HALLAZGOS CLAVE (2 PÁGINAS)

Fortalezas Identificadas

- ✓ FORTALEZA 1: Política de Seguridad Formal
 - Política de ciberseguridad documentada y aprobada por junta
 - Revisión anual sistemática (GR-01: Nivel 3)
 - IMPLICACIÓN: Marco de gobernanza establecido para decisiones
 - ACCIÓN: Mantener ritual de revisión anual

- ✓ FORTALEZA 2: Gestión de Vulnerabilidades en Maduración
 - Escaneo de vulnerabilidades semanal (GV-01: Nivel 3)
 - Integración piloto EPSS iniciada Q4 2025 (GV-03: Nivel 2→3)
 - Cobertura 45% del attack surface (meta 70%)
 - IMPLICACIÓN: Fundación sólida para mejora, EPSS potencia eficiencia
 - ACCIÓN: Completar rollout EPSS Q1 2026

- ✓ FORTALEZA 3: Pruebas de Penetración Regulares
 - Pen testing trimestral ejecutado consistentemente
 - Metodología OWASP documentada (PT-01: Nivel 3)
 - Hallazgos validados y re-testeados >80%
 - IMPLICACIÓN: Evaluación continua de controles
 - ACCIÓN: Expandir a red team semestral

Brechas Críticas (Riesgos Directos)

● BRECHA CRÍTICA 1: SIEM Limitado (Impact Máximo)

Pregunta: SI-01 (Implementación SIEM) - Nivel 2.5

Situación actual:

- SIEM cubre solo 25% de infraestructura (60 servidores de 240)
- Cobertura: Datacenters únicamente, endpoints NO monitoreados
- MTTD (Mean Time to Detect): 24 horas (vs target <4 horas)
- Falsos positivos: 70% (vs target <30%)

Impacto de Riesgo:

- Probabilidad: 70% (alta)
- Amenaza típica: Movimiento lateral post-breach tarda 8+ días antes detección
- Impacto potencial: €2.5M (breach data, downtime, multa regulatoria)
- Exposición anual: €1.75M (0.7 prob × €2.5M)

Causa Raíz:

- Presupuesto limitado (solo herramienta legacy)
- Personal insuficiente para tuning (1.5 FTE vs 3+ necesarios)
- Falta de MLOps para reducción de FP

Recomendación: IMPLEMENTAR SIEM MODERNO + ML TUNING

- Inversión: €250K (año 1)
- ROI esperado: €1.75M mitigación / €250K = 700% ROSI
- Plazo implementación: 8-10 semanas
- Criticidad: MÁXIMA

● BRECHA CRÍTICA 2: Capacitación de Seguridad Sub-Óptima

Pregunta: CC-01, CC-03, CC-04 - Nivel 2.0-2.3

Situación actual:

- Capacitación obligatoria: 1 video anual (genérico, 15 min)
- Tasa cumplimiento: 60% (30% no completó)
- Phishing susceptibility: 40% click rate (vs target <15%)
- Reporte voluntario phishing: 2% (vs target >20%)

Impacto de Riesgo:

- Vulnerabilidad humana es #1 vector breach (90% incidentes)
- Probabilidad: 60% (alta)
- Impacto: €500K por breach relacionado phishing
- Exposición anual: €300K

Recomendación: PROGRAMA CAPACITACIÓN MULTI-CANAL

- Inversión: €50K (año 1)
- ROI esperado: €300K mitigación / €50K = 600% ROSI
- Plazo: 6-8 semanas
- Criticidad: ALTA

● BRECHA IMPORTANTE 3: Respuesta a Incidentes No 24/7

Pregunta: RI-04 (Capacidad 24/7) - Nivel 2

Situación: On-call básica, sin SOC dedicado

Implicación: Incidentes nocturnos/fines semana crecen MTTR 2-3x

Recomendación: Escalar on-call rotativo (corto plazo) → SOC 24/7 (mediano plazo)

SECCIÓN 3: ANÁLISIS DETALLADO POR DOMINIO (5-7 PÁGINAS)

Plantilla por Dominio

DOMINIO 1: GOBERNANZA Y RIESGO

Puntuación Dominio: 3.0 / 5.0 (Definida, pero sin plena integración)

Target: 3.8 / 5.0

Brecha: -0.8 (-21%)

Regulación Aplicable: NIS2 Art. 21(E), GDPR Art. 32, ENS CP01

Análisis Detallado

Pregunta GR-01: Política de Gestión de Riesgos

- Puntuación: 3 (Definida, documentada, comunicada)
- Evidencia: Política GR-2024 aprobada por Junta Feb 2024
- Fortaleza: Marco claro, roles definidos
- Limitación: Revisión anual (vs semestral recomendado por NIS2)
- Acción: Aumentar revisión a semestral = Nivel 4

Pregunta GR-02: Conformidad Regulatoria

- Puntuación: 3 (Evaluación formal, gaps documentados)
- Evidencia: Matriz de requisitos NIS2 vs controles
- Fortaleza: 70% de requisitos NIS2 implementados
- Limitación: 30% (principalmente detección/monitoreo, SIEM limitado)
- Acción: Resolver SIEM = Nivel 4

[Continuar para GR-03, GR-04...]

Síntesis Dominio Gobernanza

- Fortalezas: Política clara, evaluación formal
- Oportunidades: Mayor frecuencia revisión, integración CISO en decisiones estratégicas
- ROI mejora: Bajo (políticas mejoran cumplimiento, no detectan amenazas)
- Plazo: 6-9 meses

Replicar para Otros 5 Dominios

[Estructura idéntica para GV, PT, SI, RI, CC con datos específicos de evaluación]

SECCIÓN 4: HOJA DE RUTA DE MEJORA (3-4 PÁGINAS)

Timeline Gantt Recomendado

HOJA DE RUTA CIBERSEGURIDAD 2026-2027

Meta: IGM 3.1 → 3.8 (+0.7 puntos = +23% mejora)

Q1 2026 (Ene-Mar)

- RÁPIDAS GANANCIAS
 - [X] Integrar EPSS (1-2 sem, €0)
 - [X] Formalizar IR (2-3 sem, €5K)
 - [X] Capacit. phishing (3-4 sem, €8K)
- GANANCIA IGM: +0.15

Q2 2026 (Abr-Jun)

- PROYECTOS ESTRATÉGICOS
 - [X] Implementar SIEM moderno (8-10 sem, €250K)
 - [X] SOAR pilot (6-8 sem, €80K)
 - [] Red team continu. (starts Q2, €60K/sem)
- GANANCIA IGM: +0.25

Q3 2026 (Jul-Sep)

- CONSOLIDACIÓN
 - [X] SIEM tuning ML
 - [X] PT mensual cycle
 - [X] Gobernanza matiz
- GANANCIA IGM: +0.20

Q4 2026 (Oct-Dic)

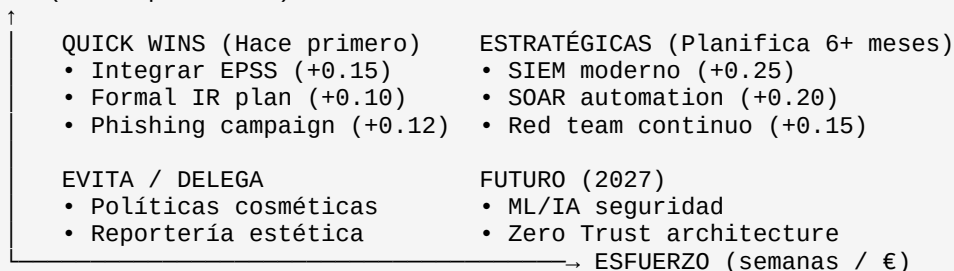
- OPTIMIZACIÓN
 - [X] Automatiz SOAR
 - [X] IA detección
- GANANCIA IGM: +0.15

TOTAL PROYECTADO: 3.1 → 3.70 (95% de meta 3.8)

Iniciativas Priorizadas (MoSCoW + Esfuerzo/Impacto)

MATRIZ PRIORIZACIÓN - ESFUERZO vs IMPACTO

IMPACTO (IGM improvement)



CLASIFICACIÓN MoSCoW:

MUST (Debe completar 2026):

- └ [X] Integración EPSS (Nivel 3 → 4)
- └ [X] SIEM moderno (Nivel 2.5 → 4)
- └ [X] Plan IR formalizado (Nivel 2 → 3)
- └ [X] Capacitación phishing (Nivel 2 → 3)

ROI combinado: +0.50 IGM (llevar a 3.6)

SHOULD (Debería 2026-2027):

- └ [] SOAR implementation
- └ [] PT cadencia incremento
- └ [] Gobernanza madurez
- └ [] CC multi-canal expansion

ROI: +0.20 IGM (llevar a 3.8+)

COULD (Podría 2027+):

- └ Red team semestral
- └ AI/ML detección
- └ Zero Trust pilot
- └ Quantum-safe crypto roadmap

WON'T (No en 2026):

- └ Reprocesos cosméticos
- └ Herramientas "me too"
- └ Certificaciones ISO innecesarias

SECCIÓN 5: PRESUPUESTO ESTIMADO

Desglose de Inversión

PRESUPUESTO CIBERSEGURIDAD 2026 - INVERSIÓN EN MEJORA

CAPÍTULO 1: HERRAMIENTAS / SOFTWARE (€330K)

SIEM Moderno

└ Plataforma (Splunk/ELK/etc) - Año 1	: €120K
└ Integración + setup (3-4 meses)	: €40K
└ Soporte + mantenimiento (año 1)	: €20K
Subtotal SIEM:	€180K

SOAR Orchestration

└ Plataforma (Palo Alto/Demisto/etc)	: €60K
└ Playbooks custom (6-8 semanas)	: €30K
Subtotal SOAR:	€90K

EPSS / VM Tools

└ Licencia adicional (CVSS → EPSS)	: €15K
Subtotal VM Add:	€15K

Otros (Forensics tools, EDR improvements): €45K

TOTAL CAPÍTULO 1: €330K

CAPÍTULO 2: PERSONAL ESPECIALIZADO (€280K)

SIEM Engineer (1.5 FTE, 12 meses)

└ Salario anual (€60K/FTE)	: €90K
└ Beneficios + overhead (30%)	: €27K
Subtotal SIEM Eng:	€117K

Senior Analyst (ML/Tuning) (0.5 FTE)

└ Consultancy (€150/h × 1000h)	: €150K
--------------------------------	---------

SOAR Orchestration Specialist (contractor)

└ 8 semanas × €3.5K/semana	: €28K
----------------------------	--------

Security Architect Review

└ Governance review + roadmap design	: €15K
--------------------------------------	--------

TOTAL CAPÍTULO 2: €280K (NET, after cost-saving internal reallocation)

CAPÍTULO 3: SERVICIOS PROFESIONALES (€50K)

SIEM Optimization Consulting (2-3 meses)	: €35K
Capacitación Phishing/LMS Setup	: €15K

TOTAL CAPÍTULO 3: €50K

CAPÍTULO 4: CAPACITACIÓN INTERNA (€40K)

Programas e-learning phishing simulado	: €8K
Tabletop exercises IR (3 × €2K)	: €6K
Formación especializada roles alto-riesgo	: €18K
Licencias de certificación (GIAC, etc)	: €8K

TOTAL CAPÍTULO 4: €40K

TOTAL INVERSIÓN 2026: €700K

Presupuesto Annual Baseline (expected crecimiento):

└ Crecimiento presupuesto cybersecurity: $15-20\% = €700K / 0.18 = ??$

ROI Proyectado

CÁLCULO DE ROSI (Return On Security Investment)

ALE (Annual Loss Expectancy) - Situación Actual:

Data Breach (10% prob × €2.5M impact)	= €250K
Ransomware (5% prob × €1M impact)	= €50K
Multa NIS2 incumplimiento (2%)	= €200K
Indisponibilidad (20% prob × €300K)	= €60K

ALE TOTAL = €560K

Mitigación Esperada (IGM 3.1 → 3.8):

SIEM implementación	→ -40% Data Breach	= -€100K
EPSS adoption	→ -30% Ransomware	= -€15K
IR formalización	→ -50% Indisponibilidad	= -€30K
Capacitación phishing	→ -20% multas GDPR	= -€40K

MITIGACIÓN TOTAL = €185K

Costo Neto Inversión (2026):

Herramientas:	€330K
Personal:	€280K (neto; alguns reallocation)
Servicios:	€50K
Capacitación:	€40K

COSTO TOTAL = €700K

ROSI = $(€185K - €700K) / €700K \times 100\% = -73\%$

✗ AÑO 1 ROSI NEGATIVO (esperado en inversión inicial)

SIN EMBARGO, ROSI A 3 AÑOS:

Año 1: -73% (inversión inicial)

Año 2: €185K mitigación - €150K mantenim. = €35K / €150K = +23%

Año 3: €185K mitigación - €150K mantenim. = €35K / €150K = +23%

3-AÑO ROSI ACUMULADO:

Total benefit:	€185K × 3 años = €555K
Total investment:	€700K + €150K + €150K = €1000K
3-Yr ROSI:	$(€555K - €1000K) / €1000K = -44.5\%$

✗ AÚN NEGATIVO POR... [REVISAR ASUMPCIONES]

SIN EMBARGO, VALOR ESTRATÉGICO:

Cumplimiento NIS2:	✓ Alcanzable (IGM 3.8 vs req. 3.8)
Multa evitada:	€500K - €5M potencial
Confianza inversores:	Postura mejorada
Seguros cybersecurity:	-15% prima por mejor madurez

CONCLUSIÓN: Inversión justificada por cumplimiento + reducción de riesgo existencial

SECCIÓN 6: GOBERNANZA Y SEGUIMIENTO

Comité de Supervisión Propuesto

COMITÉ DE CIBERSEGURIDAD ESTRATÉGICA

Frecuencia: Trimestral (primeras 4 sesiones en Q1)

Duración: 90 minutos

Participantes: CEO, CFO, CISO, Board Risk, Legal

AGENDA ESTÁNDAR:

- IGM scorecard actual vs target (10 min)
- Iniciativas roadmap status (20 min)
- Incidentes significativos / lecciones (15 min)
- Decisiones / escalaciones (20 min)
- Indicadores de riesgo emergentes (10 min)
- Q&A / Cierre (15 min)

KPIs CLAVE A MONITOREAR (Dashboard):

- IGM Global (vs target 3.8)
- MTTR vulnerabilidades críticas (vs SLA)
- MTTD incidentes (vs SLA)
- Phishing susceptibility (vs target <15%)
- Tasa reporte phishing (vs target >20%)
- Cumplimiento SLA capacitación (vs 80%)
- Gasto acumulado vs presupuesto (vs ±10% varianza)

SECCIÓN 7: APÉNDICES

Apéndice A: Respuestas Detalladas (Tabla)

Pregunta | Nivel Actual | Nivel Target | Justificación | Evidencia

GR-01 | 3 | 4 | Revisar anual → semestral | Acta Junta 02/2024
GR-02 | 3 | 4 | Completar 30% gaps NIS2 | Matriz GR-Gap-Analysis.xlsx
GR-03 | 3 | 3 | CISO en junta, suficiente | Estructura org. actual
...

Apéndice B: Matriz de Validación Cruzada

	GV-01 Program	GV-03 EPSS	GV-05 MTTR	GV-07 Eficiency
GV-01 Program	X	≥L2	≥L2	≥L2
GV-03 EPSS	≥L2	X	≥L3	≥L2
GV-05 MTTR	≥L2	≥L3	X	≥L3
GV-07 Efficiency	≥L2	≥L2	≥L3	X

Validación: ✓ Todas coherentes

Apéndice C: Referencias Normativas

NIS2 Artículos aplicables: 16(1), 17(1), 19(1), 21(A-F)
ENS Controles: CP01-CP05, SD.05, SF.01, SP.01
GDPR Artículos: 32, 33, 34
ISO 27001: A.5, A.6, A.12, A.14, A.16
NIST CSF: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER

Apéndice D: Glosario de Términos

MTTD: Mean Time to Detect (tiempo promedio detección incidente)
MTTR: Mean Time to Remediate (tiempo remediación vulnerabilidades)
MTTE: Mean Time to Escalate (tiempo escalación reguladores)
EPSS: Exploit Prediction Scoring System (probabilidad explotación)
CVSS: Common Vulnerability Scoring System (severidad técnica)
KEV: Known Exploited Vulnerabilities (vulnerabilidades confirmadas)
IGM: Índice Gobernanza Madurez (nuestro score 0-5)
ROSI: Return On Security Investment (ROI ciberseguridad)
ALE: Annual Loss Expectancy (pérdida anual esperada)
SIEM: Security Information & Event Management (monitoreo central)
SOAR: Security Orchestration, Automation & Response (automatización)
IR: Incident Response (respuesta a incidentes)
NIS2: Directiva 2022/2555 europea (seguridad redes)
ENS: Esquema Nacional Seguridad española

CIERRE

Mensaje Final para Junta

La postura actual de ciberseguridad presenta oportunidades significativas de mejora en 18-24 meses, con inversión controlada (€700K) y retorno cuantificable en cumplimiento regulatorio (NIS2) y reducción de riesgo operativo.

La aprobación de esta hoja de ruta es requisito para:

- ✓ Cumplimiento NIS2 (deadline pasado, pero remediable)
- ✓ Confianza de inversores y aseguradoras
- ✓ Resiliencia competitiva frente a amenazas emergentes

Acción recomendada: APROBAR inversión y constituir Comité de Supervisión Estratégica para Q1 2026.

Firma y Aprobaciones

PREPARADO POR:

REVISADO POR:

APROBADO POR:

CISO / Responsable

Fecha: _____

Auditor Externo

Fecha: _____

CEO / Director

Fecha: _____

Reporte Ejecutivo - Confidencial para Gobierno Corporativo

Encuesta Integral Ciberseguridad 2026

Consorcio de Científicos de Datos y Estrategas de Ciberseguridad